

Malicious Software and Intrusion

6.1 Malicious software

6.2 Virus and its phases, Virus classification

6.3 Worm, Worm propagation Model, State of Worm Technology

6.4 Trojan Horse

6.5 Intrusion and Intruders

6.6 Intrusion Detection System

6.7 Analysis Approaches: Anomaly Based, Signature Based

6.8 Honeypots

Malicious software

- Malicious software, or malware, refers to any software that is designed to harm or damage computer systems, networks, or devices without the user's knowledge or consent.
- Malware can take many different forms, and it can be distributed through a variety of channels, including email attachments, software downloads, infected websites, and social engineering tactics.
- Malware is typically created by cybercriminals and hackers to steal sensitive information, disrupt computer operations, and extort money from victims.

Advanced Persistent Threats (APTs)

- Advanced Persistent Threats (APTs) are a type of sophisticated cyberattack in which an unauthorized user gains access to a network or system and remains undetected for an extended period of time. The attackers use a range of techniques, including social engineering, phishing, and malware, to gain access and maintain control of the system.
- The "**Advanced**" component of APTs refers to the fact that these attacks are often carried out by skilled and well-funded attackers who have a deep understanding of the target system and the technology used to protect it. They may use advanced techniques such as zero-day exploits and custom malware to bypass security measures and gain access to the system.
- The "**Persistent**" component of APTs refers to the fact that the attackers remain active within the system for an extended period of time, often months or even years. They may use multiple techniques to maintain their access and control of the system, such as backdoors, command-and-control servers, and rootkits.
- The "**Threats**" component of APTs refers to the potential damage that can be caused by these attacks. APTs are often aimed at stealing sensitive data or intellectual property, disrupting critical systems, or causing financial harm to the organization. Because the attacks are often carried out by skilled and well-funded attackers, they can be difficult to detect and mitigate, and the damage caused can be significant.
- One well-known example of an Advanced Persistent Threat (APT) is the cyberattack on the United States Office of Personnel Management (OPM) in 2014 and 2015. The attackers gained access to sensitive data such as social security numbers, birth dates, and fingerprints of over 21 million current and former government employees, including military personnel and contractors. The attack was carried out using a combination of techniques, including spear phishing, malware, and social engineering, and the attackers remained undetected for several months. The attack was attributed to a group of state-sponsored Chinese hackers, and it is considered one of the most significant breaches of U.S. government data in history. This is just one example of the potential damage that can be caused by an APT attack.

Malicious software

- Viruses: A virus is a program that can replicate itself and infect other files on the system. It can spread from one computer to another through infected files, email attachments, and websites.
- Worms: A worm is a self-replicating program that can spread over a network without any user interaction. It can exploit vulnerabilities in operating systems, applications, and network protocols to infect multiple devices.
- Trojans: A Trojan, also known as a Trojan horse, is a program that disguises itself as a legitimate application but contains malicious code. It can steal sensitive information, create backdoors, and download additional malware on the system.
- Ransomware: Ransomware is a type of malware that encrypts files on the victim's system and demands payment in exchange for the decryption key. It can spread through email attachments, malicious links, and software vulnerabilities.
- Adware: Adware is a type of malware that displays unwanted advertisements on the victim's system. It can track the user's browsing history, collect personal information, and degrade system performance.
- Spyware: Spyware is a type of malware that can monitor the user's activity on the system, record keystrokes, and capture screenshots. It can steal sensitive information such as login credentials, credit card details, and personal data.

Malicious software

- Advanced Persistent Threat (APT): A type of cyberattack in which an unauthorized user gains access to a network and remains undetected for a long period of time. The attacker uses sophisticated techniques to maintain access and steal sensitive data.
- Attack kit: A set of tools that enable an attacker to launch multiple types of attacks against a system or network.
- Auto-rooter: A program designed to exploit vulnerabilities in a system to gain root-level access.
- Backdoor (trapdoor): A hidden entry point into a computer system that allows an attacker to bypass normal authentication procedures and gain unauthorized access.
- Downloaders: Malware that downloads additional malicious software onto a system without the user's knowledge or consent.
- Drive-by-download: A method of infecting a system by visiting a website that has been compromised by malware. The malware is downloaded and installed automatically without the user's knowledge.
- Exploits: Techniques used to take advantage of vulnerabilities in software or hardware to gain unauthorized access to a system.

Malicious software

- Keyloggers: Malware that captures and records keystrokes made by a user, allowing an attacker to steal sensitive information such as login credentials.
- Logic Bomb: Malware that is programmed to execute a specific action when triggered by a specific event, such as a certain date or time.
- Macro Virus: Malware that infects documents or spreadsheets and is programmed to execute when the document is opened.
- Mobile Code: Code that is designed to execute on a mobile device, such as a smartphone or tablet.
- Rootkit: Malware that is designed to hide its presence on a system and enable an attacker to maintain access and control over the system.
- Spammer programs: Programs designed to send unsolicited and unwanted email messages to large numbers of recipients.
- Zombie: A computer or device that has been compromised by malware and is being controlled remotely by an attacker.
- Bot: A program that is designed to perform automated tasks, often for malicious purposes, such as carrying out DDoS attacks or stealing sensitive information.

Virus and its phases, Virus classification

- A virus is a type of malicious software that can replicate itself and spread to other computers or devices. It can cause harm to the infected system by corrupting or deleting files, stealing data, or controlling the system for malicious purposes.
- A computer virus typically consists of **three** components: the **infection** mechanism (or infection vector), which enables the virus to spread and replicate; the **trigger**, which activates or delivers the virus payload; and the **payload** itself, which is the actual code or instructions executed by the virus.

Virus and its phases, Virus classification

Phases of a Virus:

- **Dormant Phase:** The virus is inactive and hidden in the system, waiting for a trigger to activate it.
- **Propagation Phase:** The virus replicates itself and spreads to other systems or devices through various means such as email attachments, infected files, or network vulnerabilities.
- **Triggering Phase:** The virus is activated by a specific event or trigger, such as a certain date or time or a specific user action.
- **Execution Phase:** The virus executes its malicious code, which can include deleting files, stealing data, or controlling the system.
- **Concealment Phase:** The virus attempts to hide its presence and avoid detection by antivirus software or other security measures.

Types of viruses

File Infector Viruses: These viruses attach themselves to executable files and infect other files when the infected file is executed.

Boot Sector Viruses: These viruses infect the boot sector of a disk, which allows them to execute before the operating system is loaded.

Macro Viruses: These viruses infect macro-enabled documents, such as Microsoft Word or Excel files, and execute when the document is opened.

Email Viruses: These viruses spread through email attachments and can infect other systems when the infected email is opened.

Worms: These are self-replicating viruses that spread through networks and can infect other systems without user intervention.

Trojan Horses: These are programs that appear to be legitimate but contain hidden malicious code that can cause harm to the system or steal data.

Ransomware: This is a type of malware that encrypts the victim's files and demands payment in exchange for the decryption key.

Rootkits: These are malicious programs that are designed to hide their presence on the infected system and enable an attacker to maintain control over the system.

Types of viruses

- Encrypted virus: An encrypted virus is a type of computer virus that has been intentionally encoded or encrypted by its author to hide its malicious code from detection by antivirus software. When the virus is executed, it decrypts itself in order to infect the system.
- Stealth virus: A stealth virus is a type of computer virus that is designed to hide its presence from antivirus software and other security measures. It does this by actively monitoring system activity and modifying its own code to avoid detection.
- Polymorphic virus: A polymorphic virus is a type of computer virus that can mutate or change its own code in order to avoid detection by antivirus software. Each time the virus infects a new system, it changes its own code, making it difficult for antivirus software to detect and remove.
- Metamorphic virus: A metamorphic virus is a type of computer virus that can completely rewrite its own code in order to avoid detection by antivirus software. Unlike polymorphic viruses, which only change certain parts of their code, metamorphic viruses can change their entire structure and still maintain their functionality. This makes them even more difficult to detect and remove than polymorphic viruses.

Worm, Worm propagation Model, State of Worm Technology

- A worm is a type of malware that is designed to spread from one computer to another. Unlike viruses, which typically require user interaction (such as opening a file or clicking a link) to propagate, worms can spread automatically through network connections.
- Worms typically exploit vulnerabilities in software or operating systems to gain access to a computer, and then use that access to replicate themselves and spread to other computers on the same network.
- Worms can cause a range of problems, from consuming network bandwidth and slowing down computer systems, to stealing sensitive information and causing damage to critical infrastructure.
- Some well-known examples of computer worms include the Morris Worm, which caused widespread disruption to the early internet in 1988, and the Conficker Worm, which infected millions of computers worldwide in 2008.

Worm propagation models

Worm propagation models are mathematical or computational models that attempt to simulate how a worm spreads through a network or system. These models can be used to better understand how worms behave and to test potential defense strategies.

There are several different types of worm propagation models, but one commonly used approach is known as the **SIR model**. The SIR model is a simple epidemiological model that breaks down the population into three groups:

Susceptible: individuals who have not been infected and can potentially become infected.

Infected: individuals who are currently infected and can infect susceptible individuals.

Recovered: individuals who have recovered from the infection and are no longer susceptible or infectious.

Worm propagation models

$$dI(t)/dt = \beta I(t) S(t)$$

Where,

$I(t)$ = number of individuals infected as of time t .

$S(t)$ = number of susceptible individuals (susceptible to infection by not yet finished) at time t .

β = infection rate

N = size of the population, $N = I(t) + S(t)$

The equation $dI(t)/dt = \beta I(t) S(t)$ is a simplified version of the SIR model for worm propagation. It describes how the number of infected computers changes over time based on the infection rate (β) and the number of susceptible computers (S) at time t .

The term $\beta I(t) S(t)$ represents the rate at which susceptible computers become infected, and the derivative $dI(t)/dt$ represents the rate of change in the number of infected computers over time. By integrating this equation over time, we can simulate how the number of infected computers grows and spreads through the population.

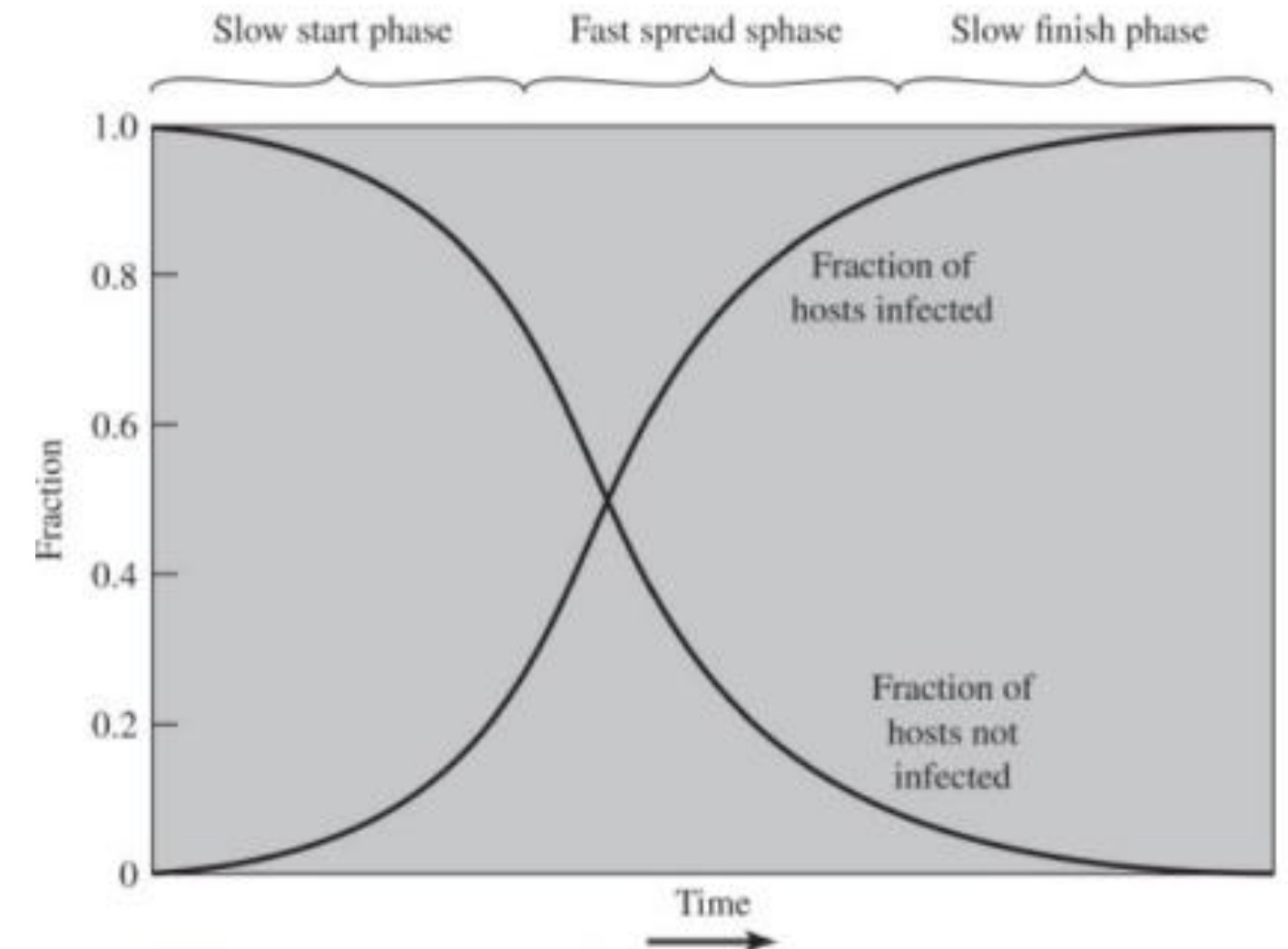


Figure 6.2 Worm Propagation Model

Worm propagation models

- The state of the art in worm technology refers to the latest developments and trends in the design, propagation, and mitigation of computer worms. Here are some of the current trends and technologies in worm technology:
- **Multiplatform:** Modern worms are no longer limited to attacking a single platform, such as Windows. Instead, they can target a variety of platforms, including Unix, Linux, and macOS.
- **Multi-vector:** Advanced worms can use multiple attack vectors, such as exploiting vulnerabilities in web servers, browsers, email clients, or other network-based applications.
- **Rapid propagation:** Worms can spread quickly and efficiently across a network or the internet using a variety of techniques, including exploiting network protocols or software vulnerabilities, social engineering, or phishing attacks.
- **Polymorphic and metamorphic:** To evade detection, modern worms can use polymorphic or metamorphic techniques to generate new code on the fly or change their appearance and behavior as they propagate.
- **Botnet integration:** Many worms are designed to join or create botnets, which can be used for a variety of malicious purposes, including spamming, distributed denial of service (DDoS) attacks, or theft of sensitive data.
- **Zero-day exploits:** Some worms use zero-day exploits, which are previously unknown vulnerabilities in software or hardware that can be exploited to gain access to a system.
- **Advanced evasion techniques:** Worms can use advanced evasion techniques to bypass security systems, such as encryption, obfuscation, or fragmentation.
- **Machine learning:** Security vendors are increasingly using machine learning and artificial intelligence to detect and mitigate worm attacks. These techniques can analyze large volumes of data and detect anomalous behavior that may indicate the presence of a worm.

Trojan horse

- Trojan horse, often referred to as just a "Trojan," is a type of malicious software that disguises itself as legitimate software to trick users into installing or executing it on their computer or mobile device.
- Once installed, a Trojan can perform a variety of malicious actions, such as stealing sensitive data, destroying files, or installing additional malware.
- The term "Trojan horse" comes from the ancient Greek story of the Trojan War, in which the Greeks used a giant wooden horse to sneak into the city of Troy and defeat the Trojans.
- In a similar way, a Trojan horse malware program hides its malicious code inside legitimate-looking software, often using social engineering tactics to persuade users to install or run it.

Different types of Trojan horses

- Remote Access Trojan (RAT): This type of Trojan horse allows an attacker to take remote control of a victim's computer or mobile device, giving them complete access to files, keystrokes, and other sensitive information.
- Banking Trojan: A banking Trojan is designed to steal banking credentials or other financial information from victims, often by capturing login credentials, intercepting transactions, or redirecting users to fake banking websites.
- Ransomware: Ransomware Trojans encrypt the victim's files and demand payment in exchange for the decryption key, often using Bitcoin or other untraceable payment methods.
- Backdoor Trojan: A backdoor Trojan creates a secret backdoor into a victim's system, allowing attackers to access the system at any time and use it for malicious purposes.
- DDoS Trojan: A DDoS Trojan turns a victim's computer or mobile device into a "bot" that can be used to launch distributed denial of service (DDoS) attacks against websites or other online services.
- Fake antivirus: This type of Trojan disguises itself as legitimate antivirus software, but in reality, it is just a fake program designed to trick users into paying for useless software or giving up personal information.

Intrusion and Intruders

- In computer security, an intrusion is an unauthorized attempt to gain access to a computer system or network.
- An intruder is a person or program that attempts to break into a system or network without authorization.
- Intruders are often referred to as hackers, attackers, or malicious actors.
- Intrusion refers to any unauthorized attempt to access or disrupt a computer system or network.
- An intruder is someone who attempts to gain unauthorized access to a computer system or network with malicious intent.

Different classes of intruders

- Script Kiddies: These are typically amateur or inexperienced attackers who use pre-made scripts or tools to launch attacks against vulnerable systems. Script Kiddies often lack the knowledge and expertise to create their own tools or exploits and rely on others' work to carry out their attacks.
- Hacktivists: These are individuals or groups who use hacking as a form of activism to promote a political or social cause. Hacktivists often target government or corporate websites, defacing or taking them down to raise awareness of their cause.
- Cybercriminals: These are individuals or groups who engage in hacking for financial gain. Cybercriminals may target personal information, such as credit card numbers or login credentials, which they can use to commit fraud or identity theft.
- State-Sponsored Attackers: These are attackers who are supported by a government or other state actor. State-sponsored attackers may engage in espionage, sabotage, or other activities to further their government's interests.
- Insiders: These are individuals who have authorized access to a computer system or network but abuse that access for malicious purposes. Insiders may be motivated by financial gain, revenge, or other personal reasons.

Intruder Behavior

- **Target Acquisition and Information Gathering:** Where the attacker identifies and characterizes the target systems using publicly available information, both technical and non-technical, and the use of network exploration tools to map target resources.
- **Initial Access:** The initial access to a target system, typically by exploiting a remote network vulnerability, by guessing weak authentication credentials used in a remote service, or via the installation of malware on the system using some form of social engineering or drive-by-download attack.
- **Privilege Escalation:** Actions taken on the system, typically via a local access vulnerability, to increase the privileges available to the attacker to enable their desired goals on the target system.
- **Information Gathering or System Exploit:** Actions by the attacker to access or modify information or resources on the system, or to navigate to another target system.
- **Maintaining Access:** Actions such as the installation of backdoors or other malicious software, or through the addition of covert authentication credentials or other configuration changes to the system, to enable continued access by the attacker after the initial attack.
- **Covering Tracks:** Where the attacker disables or edits audit logs, to remove evidence of attack activity, and uses rootkits and other measures to hide covertly installed files or code

Intrusion Detection System

- Intrusion Detection System (IDS) is a security technology that monitors network and system activities for malicious or unauthorized activities. IDSs work by analyzing network traffic or system logs, looking for patterns or anomalies that indicate potential intrusions or attacks. There are two main types of IDSs:
- Host-based IDS (HIDS): A HIDS is installed on a single host or system and monitors activity on that system. It can detect both external attacks and internal misuse or abuse by authorized users. HIDSs use log files, system calls, and kernel alerts to identify security events.
- Network-based IDS (NIDS): A NIDS is deployed on a network and monitors network traffic for suspicious activity. It can detect attacks that are aimed at multiple hosts or systems, as well as attacks that are hidden within encrypted traffic. NIDSs use signatures, protocols, and statistical analysis to detect security events.
- Distributed or hybrid IDS: Combines information from a number of sensors, often both host and network-based, in a central analyzer that is able to better identify and respond to intrusion activity.

Intrusion Detection System

- Sensors: The sensors are responsible for collecting and analyzing network traffic or system activity data. They can be placed at different points within the network or system, including at the perimeter, on critical servers, or on endpoints.
- Analyzers: The analyzers process the data collected by the sensors and compare it to known patterns of attack or normal behavior. They use various techniques, including rule-based systems, anomaly detection, and machine learning, to identify potential intrusions.
- User Interface: The user interface is where security analysts can view and investigate alerts generated by the IDS. It provides detailed information about the detected intrusion, including the type of attack, the affected system, and the severity of the intrusion. It also allows security analysts to take actions, such as blocking the attacker's IP address or quarantining an affected system.

Analysis Approaches: Anomaly Based, Signature Based

- IDSs can operate in one of two modes: signature-based or anomaly-based.
- Signature-based IDSs use predefined rules or signatures to detect known attacks. These signatures are based on patterns of traffic or system activity that have been identified as malicious. Signature-based IDSs are easy to deploy and can detect known threats quickly.
- Anomaly-based IDSs use statistical analysis to detect deviations from normal patterns of activity. They establish a baseline of normal activity and then look for any unusual activity that could indicate an attack. Anomaly-based IDSs are more effective at detecting unknown threats or zero-day attacks, but they can also generate more false positives.
- IDSs can be used to detect a wide range of threats, including network-based attacks such as port scans and denial-of-service (DoS) attacks, and host-based attacks such as malware infections and unauthorized access. When an IDS detects a potential intrusion, it can alert security personnel, generate an incident report, or take other automated actions to mitigate the threat.

Honeytrap

- A honeytrap is a **security mechanism** designed to **detect, deflect, or counteract** attempts at unauthorized use of information systems.
- It is an **intentionally vulnerable system** or network that is set up to **lure attackers** into interacting with it, with the aim of detecting and analyzing their behavior.
- Honeytraps can be thought of as **decoys or traps**, designed to distract attackers from real production systems while providing a valuable source of intelligence to security teams.
- Honeytraps can be classified into two main types: **production honeytraps** and **research honeytraps**.
- Production honeytraps are used in live environments to provide a **high-fidelity** representation of the production environment, while research honeytraps are used in **controlled environments** for research purposes.
- Honeytraps can also be classified based on their level of interaction, ranging from low-interaction honeytraps, which simulate a limited set of services or applications, to high-interaction honeytraps, which provide a complete operating system environment that can be accessed by attackers.

Honeypot

- Honeypots are computer security mechanisms that are designed to detect, deflect, or study attempts at unauthorized use of information systems.
- Honeypots can be either physical or virtual, and they are essentially decoy systems that are designed to look vulnerable to attack.
- The idea behind honeypots is to lure attackers away from real systems and to gather information about the attackers and their methods.
- There are several reasons why organizations might choose to use honeypots. One reason is to gain intelligence about attackers and their methods.
- By studying the actions of attackers in a controlled environment, organizations can learn about their techniques, tools, and motives. This information can then be used to better protect real systems.
- Another reason to use honeypots is to divert attackers away from real systems. By presenting attackers with a decoy system that appears to be vulnerable, organizations can distract them from real systems and minimize the damage that they can cause.
- Finally, honeypots can be used to detect and alert administrators to attempted attacks. By monitoring honeypots for suspicious activity, organizations can be alerted to attacks before they cause significant damage.

Honeypot

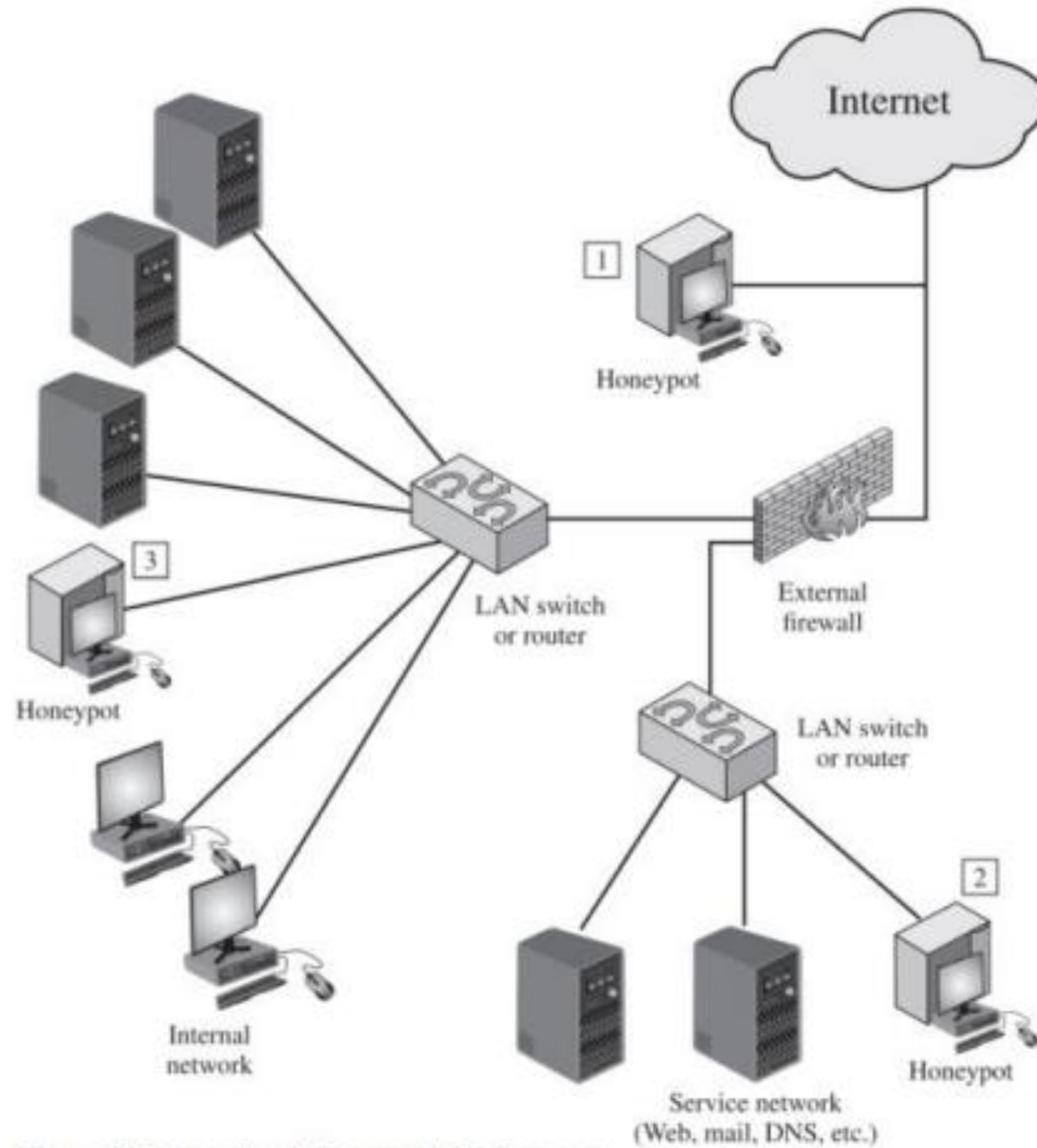


Figure 8.8 Example of Honeypot Deployment